

■IDENTIFICATION AND AUTHENTICATION POLICY

Organization: Keith the Drone Guy LLC

Control: 3.5.4 - Replay-Resistant Authentication

Version: 1.2 | Effective: 2026-01-15

Owner: Keith Merritt, Owner-Operator | Approved: Keith Merritt, Owner-Operator

1. PURPOSE

This policy requires Keith the Drone Guy LLC to employ replay-resistant authentication mechanisms, per NIST SP 800-171 Rev. 2 control 3.5.4.

2. SCOPE

All authentication mechanisms used to access Keith the Drone Guy LLC CUI systems.

3. REQUIREMENTS

- a. Authentication protocols use challenge-response or cryptographic nonce mechanisms.
- b. Kerberos v5 is used for domain authentication (replay protection via timestamps and nonces).
- c. Azure AD authentication uses OAuth 2.0 tokens with expiration and nonce.
- d. NTLM v1 is disabled; NTLMv2 may be used only where Kerberos is not supported.
- e. Authentication tokens are short-lived and cannot be replayed after expiration.

4. RESPONSIBILITY

Keith Merritt, Owner-Operator, configures authentication protocols with replay resistance.

5. ENFORCEMENT

Authentication protocols without replay protection are prohibited.

Signed: Keith Merritt, Owner-Operator | Keith the Drone Guy LLC | 2026-01-15